GITHUB 安全团队 · 2026 年 4 月

保护 `git push` 管道

应对一个关键远程代码执行漏洞 · CVE-2026-3854

由 Wiz 上报 · 不到 2 小时完成修复 · 已确认无漏洞利用

第一部分

理解漏洞

漏洞赏金报告

来源

Wiz 安全研究人员通过 GitHub 漏洞赏金计划提交

2026 年 3 月 4 日

严重 — 远程代码执行（RCE）

受影响平台

- github.com
- GitHub Enterprise Cloud
- GitHub Enterprise Cloud（数据驻留版）
- GitHub Enterprise Cloud（EMU 版）
- GitHub Enterprise Server

攻击条件：任何拥有推送权限的用户——包括对其自己创建的仓库——都可以在处理其 `git push` 的服务器上实现任意命令执行。

推送管道的工作原理

用户推送代码时，操作会经过多个内部服务并交换元数据：

git push
客户端

网关
内部路由

钩子运行器
沙箱隔离

Git 存储
仓库后端

各服务之间通过**使用分隔符的内部协议**交换元数据（仓库类型、处理环境等）。

推送选项（push options）是 git 的一项正当功能，允许客户端在推送时向服务器发送键值字符串。这一功能成为了攻击入口。

注入机制

用户提供的推送选项值在**未经任何过滤的情况下**被嵌入内部元数据：

```
# 正常的推送选项（无害）
git push --push-option="key=value"

# 精心构造的推送选项（利用漏洞）
git push --push-option="key=value;injected_field=malicious"
```

用户输入中的 `;` 被内部元数据格式解析为字段分隔符，攻击者得以：

第一步

覆盖**处理环境**字段

第二步

绕过钩子执行的**沙箱防护**

第三步

在服务器上**执行任意命令**

第二部分

应急响应

不到两小时：响应时间线

< 2h
从报告到修复部署

40m
内部复现漏洞

T+0	收到 Wiz 提交的漏洞赏金报告
T+40m	内部**成功复现**漏洞，确认严重性
UTC 17:45	**定位**根本原因
UTC 19:00	修复方案**部署至 github.com**
当天	启动取证调查

修复方案：输入过滤

根本原因很明确：**用户提供的推送选项值在嵌入内部元数据前未经过滤。**

✕ 修复前

```
metadata = build_metadata(
  env=env,
  push_options=user_input  # 原始值
)
```

✓ 修复后

```
metadata = build_metadata(
  env=env,
  push_options=sanitize(user_input)
)
```

> 用户提供的值现在在写入内部元数据前会经过**过滤处理**，分隔符字符不再能被解析为字段分隔符。

GitHub Enterprise Server 补丁

GitHub Enterprise Cloud 和 github.com 已于 2026 年 3 月 4 日完成修复。**GHES 用户须立即升级：**

`3.14.25+` `3.15.20+` `3.16.16+` `3.17.13+`

`3.18.7+` `3.19.4+` `3.20.0+`

⚠ GHES 上的漏洞利用需要**具有推送权限的已认证用户**。建议检查 `/var/log/github-audit.log`，查找推送选项中含有 `;` 的推送操作。

CVE 编号：**CVE-2026-3854**

第三部分

取证调查
与纵深防御

发现信号：异常代码路径

该漏洞的利用会强制服务器进入一条**正常操作中从不会触发的代码路径**——攻击者无法规避这一点。

正常操作

走标准代码路径

无异常日志

漏洞利用尝试

强制进入**异常代码路径**

遥测系统记录日志

GitHub 对历史日志中该异常代码路径的**每一次触发记录**进行了全面排查。

调查结论

0	0	0
未授权用户触发了异常路径	客户数据被访问或篡改	数据外泄事件

异常代码路径的**所有触发记录**均来自 Wiz 研究人员在测试过程中的操作。

报告提交前未发生任何漏洞利用。**github.com 和 GHEC 用户无需采取任何操作。**

纵深防御

调查还发现了一个次要问题：存在漏洞的代码路径存在于本不应部署它的环境磁盘上。

根本原因

部署模式更换时，**未将正确的排除规则**延续到新模型，导致该代码路径出现在不应存在的环境中。

额外加固措施

该不必要的代码路径已从**所有不应存在的环境中移除**，有效降低未来类似问题的爆炸半径。

> *纵深防御至关重要。即便未来发现类似的注入漏洞，此次加固也能大幅限制攻击者可利用的空间。*

总结与致谢

关键经验

- **对所有用户输入进行过滤**，在嵌入内部协议前处理，即使是"可信"元数据也不例外
- **将异常代码路径作为取证信号**——设计系统记录攻击者无法隐藏的行为
- **纵深防御**：从不需要它的环境中移除多余代码路径
- **漏洞赏金计划有效**——负责任披露使 GitHub 能够在 2 小时内完成修复

致谢

Wiz 安全研究团队 — 报告详尽、影响论证清晰、负责任披露

获得 GitHub 漏洞赏金计划历史上最高奖励之一

CVE 编号：**CVE-2026-3854**

披露平台：**bounty.github.com**